

RESUMEN DE LA DIRECTIVA NIS 2 (UE) 2022/2555

1. INTRODUCCIÓN Y CONTEXTO

La Directiva (UE) 2022/2555, conocida como NIS 2, es el pilar de la ciberseguridad en la Unión Europea. Fue publicada en diciembre de 2022 y debía ser transpuesta por los Estados miembros antes del 17 de octubre de 2024. Sustituye a la anterior Directiva NIS (2016/1148), ampliando y endureciendo significativamente sus requisitos.

Objetivo principal: Alcanzar un elevado nivel común de ciberseguridad en toda la UE, mejorando la resiliencia de redes y sistemas de información frente a incidentes y ataques cibernéticos.

2. ÁMBITO DE APLICACIÓN

NIS 2 amplía drásticamente los sectores cubiertos: de 7+3 sectores en NIS 1 a 18 sectores críticos, divididos en dos categorías:

A) Sectores de alta criticidad

- Energía (electricidad, petróleo, gas, renovables)
- Transporte (aéreo, ferroviario, marítimo, por carretera)
- Banca e infraestructuras de mercados financieros
- Salud (incluidos laboratorios e investigación médica)
- Agua potable y aguas residuales
- Infraestructuras digitales (CDN, DNS, centros de datos, proveedores de cloud, etc.)
- Administración pública (central y regional)
- Gestión de servicios TIC B2B
- Espacio

B) Otros sectores críticos

- Servicios postales y de mensajería
- Gestión de residuos
- Fabricación de productos críticos (máquinas, dispositivos médicos, vehículos, productos químicos, alimentos)
- Proveedores de servicios digitales (marketplaces, motores de búsqueda, redes sociales)
- Investigación

Clasificación de entidades:

- Entidades esenciales: Supervisión proactiva (auditorías, inspecciones).
- Entidades importantes: Supervisión reactiva (más ligera, a posteriori).

Afecta a medianas y grandes empresas, y también a pequeñas si prestan servicios especialmente críticos o son clave para la economía o la sociedad.

3. PRINCIPALES OBLIGACIONES

Las entidades deben adoptar medidas proporcionadas y adecuadas de gestión de riesgos de ciberseguridad, bajo un enfoque "all-hazards" (todos los peligros). Se enumeran 10 ámbitos obligatorios:

1. Análisis de riesgos y políticas de seguridad de la información.
2. Gestión de incidentes (plan de respuesta).
3. Continuidad del negocio (copias de seguridad, recuperación ante desastres, planes de crisis).
4. Seguridad en la cadena de suministro (evaluación de proveedores y relaciones con ellos).
5. Seguridad en la adquisición, desarrollo y mantenimiento de sistemas (incluye gestión de vulnerabilidades).
6. Evaluación de la eficacia de las medidas de ciberseguridad.
7. Higiene básica y formación en ciberseguridad (concienciación del personal).
8. Criptografía y control de accesos.
9. Seguridad de recursos humanos (gestión de accesos y concienciación continua).
10. Autenticación multifactor (MFA) y comunicaciones seguras.

Estas medidas deben aplicarse de forma proporcional al tamaño, sector y nivel de riesgo de la entidad.

4. NOTIFICACIÓN DE INCIDENTES

NIS 2 introduce plazos notablemente más cortos que su predecesora:

- Notificación temprana: 24 horas desde el conocimiento inicial del incidente.
- Notificación actualizada: 72 horas (con detalles más precisos).
- Informe final: 1 mes (o antes, si se dispone de toda la información).
- Además, se debe comunicar a clientes o usuarios si existe un riesgo significativo.

Esto exige a las entidades disponer de capacidades de detección y respuesta muy ágiles.

5. GOBERNANZA Y RESPONSABILIDAD DE LA DIRECCIÓN

Los órganos de administración y dirección (alta dirección) quedan directamente implicados:

- Deben aprobar y supervisar las medidas de ciberseguridad.
- Recibir formación obligatoria en ciberseguridad.
- Responder personalmente por incumplimientos graves (posible responsabilidad civil e incluso penal en algunos Estados miembros).

Esto equipara la ciberseguridad a otras obligaciones fiduciarias de la dirección, similar al RGPD en protección de datos.

6. COOPERACIÓN Y ESTRUCTURAS EUROPEAS

Se refuerza el marco de cooperación:

- Grupo de Cooperación NIS (estrategia e intercambio de información).
- Red CSIRTs (equipos de respuesta a incidentes de seguridad informática) con mayor coordinación.
- EU-CyCLONe (red de apoyo para crisis cibernéticas a gran escala, con cooperación operativa entre Estados miembros).
- Divulgación coordinada de vulnerabilidades (CVD) como práctica obligatoria.
- Registro europeo de vulnerabilidades (coordinación en la divulgación y solución de fallos).

7. SUPERVISIÓN Y SANCIONES

Las sanciones son mucho más elevadas que en NIS 1:

Tipo de entidad	Multa máxima
Entidades esenciales	10 millones € o 2% de la facturación global anual (el mayor de los dos)
Entidades importantes	7 millones € o 1,4% de la facturación global anual (el mayor)

Además, pueden imponerse:

- Requerimientos de cese de conducta.
- Publicación de las sanciones.
- Suspensión de certificaciones o autorizaciones.

Las autoridades de supervisión pueden realizar auditorías, inspecciones in situ y solicitar documentación.

8. TRANSICIÓN DESDE NIS 1: PRINCIPALES CAMBIOS

Aspecto	NIS 1 (2016)	NIS 2 (2022)
Sectores cubiertos	7+3	18
Tipo de supervisión	Reactiva	Proactiva para esenciales
Plazos de notificación	Sin plazos fijos estrictos	24h / 72h / 1 mes
Responsabilidad dirección	Poco definida	Directa, con formación y sanciones
Seguridad cadena suministro	No exigida explícitamente	Obligatoria
Multas máximas	Bajas o inexistentes en muchos países	Hasta 10M€ o 2% facturación

9. SITUACIÓN EN ESPAÑA

- Fecha límite de transposición: 17 de octubre de 2024 (incumplida).
- Estado actual: Se aprobó un anteproyecto de ley, pero la transposición final se espera a lo largo de 2026.
- Mientras tanto, siguen aplicándose los reales decretos de NIS 1 y el Esquema Nacional de Seguridad, pero las entidades sujetas a NIS 2 deberían prepararse voluntariamente

para cumplir con los nuevos requisitos (cadena de suministro, plazos de notificación, responsabilidad de dirección, etc.).

10. CONCLUSIONES CLAVE

NIS 2 supone un cambio de paradigma en la ciberseguridad europea:

- Pasa de un enfoque voluntarista (NIS 1) a uno obligatorio y prescriptivo.
- Exige gestión integral de riesgos incluyendo proveedores y cadena de suministro.
- Impone notificación ultrarrápida de incidentes.
- Responsabiliza personalmente a la alta dirección.
- Cubre prácticamente todos los sectores críticos de la economía y la sociedad.

Equivalencia: Es para la ciberseguridad lo que el RGPD fue para la protección de datos.